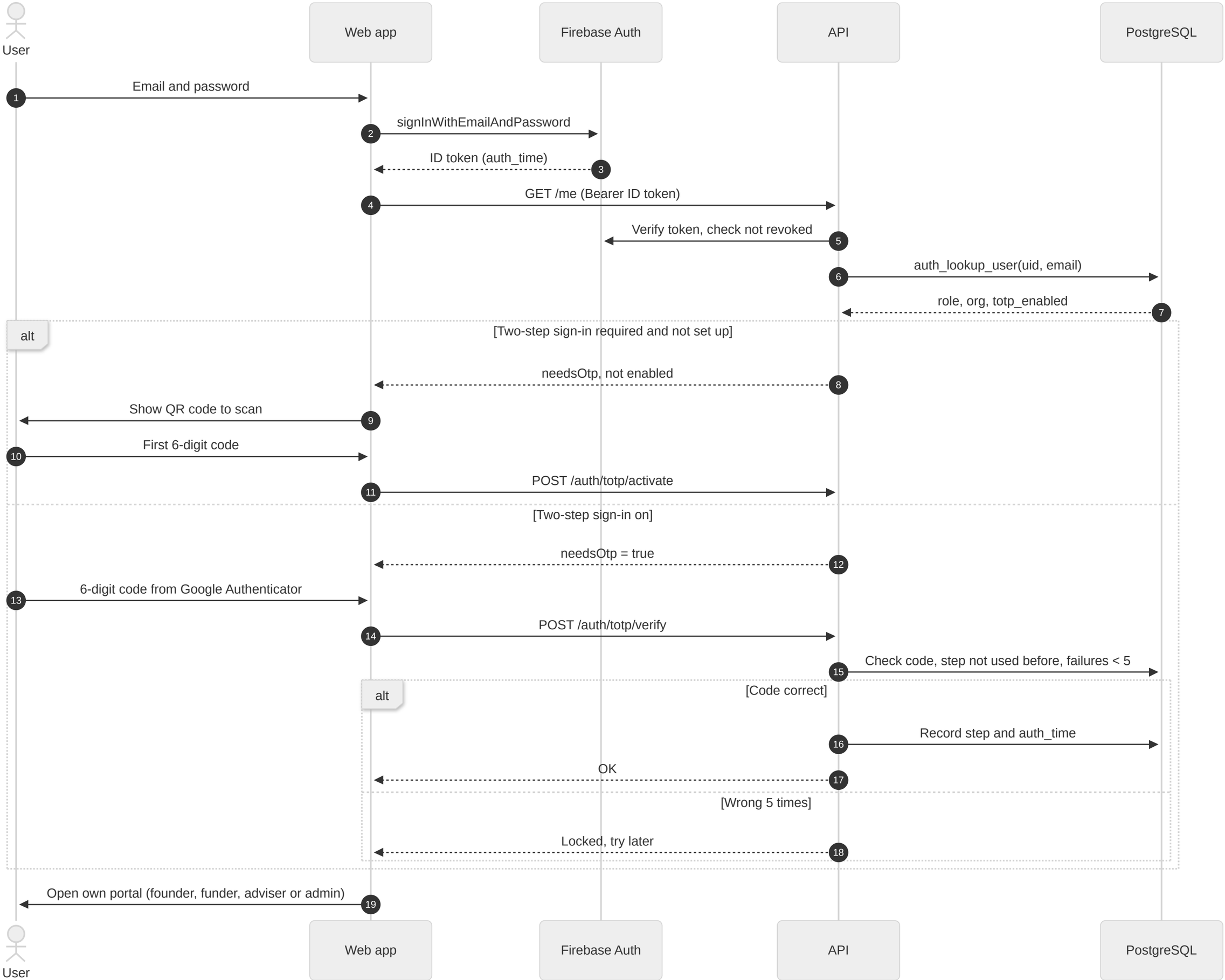

User
Web app
Firebase Auth
API
PostgreSQL
1
Email and password
2
signInWithEmailAndPassword
3
ID token (auth_time)
4
GET /me (Bearer ID token)
5
Verify token, check not revoked
6
auth_lookup_user(uid, email)
7
role, org, totp_enabled
alt
[Two-step sign-in required and not set up]
8
needsOtp, not enabled
9
Show QR code to scan
10
First 6-digit code
11
POST /auth/totp/activate
[Two-step sign-in on]
12
needsOtp = true
13
6-digit code from Google Authenticator
14
POST /auth/totp/verify
15
Check code, step not used before, failures < 5
alt
[Code correct]
16
Record step and auth_time
17
OK
[Wrong 5 times]
18
Locked, try later
19
Open own portal (founder, funder, adviser or admin)
User
Web app
Firebase Auth
API
PostgreSQL